

RAPPORT D'ANALYSE DES MENACES CYBER

SL1PCONNECT

Wazuh SOC · MITRE ATT&CK · CTI
Retail · Santé · IoT · Infrastructure Industrielle

juin 2026

1. Cartographie des actifs critiques

Identification des éléments vitaux de SL1PCONNECT en tenant compte des enjeux de conformité (RGPD/HDS) et des menaces ciblées.

Actif Critique	Description Technique	Criticité	Enjeu Métier
Identités et Accès (AD)	Bender / Roger (AD Windows 2022)	Critique	Gère les droits de 512 utilisateurs. Cible principale pour l'extraction NTDS.dit (Scattered Spider).
Bases de données Santé	PGSQL-HOST (PostgreSQL 12 sur OVH)	Critique	Héberge des données physiologiques (art. 9 RGPD). Vol ou chiffrement bloque la certification HDS et la levée de fonds.
Plateforme E-commerce	Cartman, Stan, Kyle, Kenny (Nginx)	Critique	Traite les transactions financières. Cible directe d'attaques Web Skimming (FIN6).
Plateforme IoT Cloud	DOCKER-HOST (Conteneurs sur OVH)	Élevée	Traitement en continu des données IoT. Surface d'attaque exposée sur Internet.
Infrastructure Industrielle	AS400, Automates Siemens (Perpignan)	Élevée	Pilote la logistique. Obsolescence (Windows XP) accroît le risque de ransomware (FIN8).

2. Identification des menaces principales — Mapping MITRE ATT&CK

Mapping des techniques employées par les groupes ciblant les secteurs Retail et Santé, basé sur la Cyber Threat Intelligence.

Groupe	Objectif	Accès Initial	Exécution & Mouvement	Impact & Exfiltration
Scattered Spider	Extorsion Ransomware	T1566.004 / T1598.004 — Usurpation support IT (appels/SMS) T1621 — Fatigue MFA	T1219.002 — Outils RMM légitimes (AnyDesk, TeamViewer) T1003.003 — Extraction NTDS.dit via VSS	T1486 — Chiffrement (BlackCat / DragonForce)
FIN6	Vol de données bancaires	T1190 — Exploitation d'applications exposées	T1059.007 — JavaScript malveillant (e-commerce) T1547.001 — Persistance registre Run	T1005 — Collecte données cartes T1048.003 — Exfiltration HTTP POST
APT41	Espionnage / Vol de données	T1190 — Failles applications publiques T1566.001 — Spearphishing (.chm)	T1053.005 — Tâches planifiées via GPOT1021.001 — Mouvement latéral RDP	T1486 — Chiffrement (BitLocker, RaaS) T1685.005 — Suppression logs Windows
FIN8	Ransomware / Perturbation	T1566.001 — Spearphishing (macros Word)	T1021.001 — Mouvement latéral RDPT1053.005 — Backdoors RDP planifiés	T1486 — Ransomwares (Ragnar Locker, White Rabbit)

3 & 4. Scénarios d'attaque — Documentation et Priorisation

Priorité 1 Compromission des Identités et Ransomware — Scattered Spider / FIN8

Argumentation :

- Équipe IT restreinte (3 admins sys, 1 alternante), poste RSSI vacant.
- Vulnérabilité élevée à l'ingénierie sociale ciblée (T1566.004).
- Compromission de l'AD permettrait un contrôle total du SI.

Déroulement :

- — Accès Initial
 - Usurpation d'identité du support IT par appel/SMS. Fatigue MFA (T1621) pour valider une connexion frauduleuse.
- — Mouvement Latéral
 - Installation d'un outil RMM légitime (AnyDesk/TeamViewer — T1219.002) pour contourner le filtrage réseau.
- — Élévation de privilèges
 - Sur Bender (DC) : génération d'un cliché VSS pour extraire NTDS.dit (T1003.003) et récupérer les credentials admins.
- — Impact
 - Déploiement ransomware (T1486) via RDP (T1021.001) sur le parc bureautique et industriel. Arrêt des opérations.

Priorité 2 E-Skimming et Fraude Bancaire — FIN6

Argumentation :

- Boutique en ligne sur Cartman/Stam — surface web exposée.
- Précédent démontré : fuite de 150 e-mails via SQLi (mars 2024).

Déroulement :

- — Accès Initial
 - Exploitation d'une vulnérabilité web non patchée (T1190) sur les serveurs Nginx.
- — Exécution
 - Injection d'un script malveillant dans les pages de paiement (T1059.007). Persistance via registre Run (T1547.001).
- — Impact
 - Collecte silencieuse des données de cartes (T1005). Exfiltration via HTTP POST (T1048.003) vers un domaine contrôlé.

Priorité 3 Vol de données de santé et dissimulation — APT41

Argumentation :

- Conteneurs Docker en mode root — évocation triviale.
- Secrets PostgreSQL exposés en clair dans les variables d'environnement.
- Données physiologiques (art. 9 RGPD) — cible pour acteurs étatiques/para-étatiques.

Déroulement :

- — Accès Initial
 - Exploitation d'un endpoint API BOXER non authentifié (T1190).
- — Exécution
 - Évasion de conteneur via privilèges root. Extraction des credentials PostgreSQL depuis les variables d'environnement.

- Impact
 - Exfiltration des données PGSQL-HOST. Effacement des journaux Windows (T1685.005) pour couvrir les traces.

5. Use Cases SOC — Règles de détection Wazuh

Traduction des TTPs identifiés et des vulnérabilités d'audit en règles de détection actionnables pour le SOC Wazuh.

Use Case	Règle SIEM	Source / TTP	Config Wazuh	Logique de Détection
SOC-U C-01	Création anormale de VSS	Priorité 1 / T1003.003	Agent Windows (Sysmon) sur AD	Détection de vssadmin.exe create shadow ou accès à C:\Windows\NTDS\ntds.dit
SOC-U C-02	Exécution RMM non autorisé	Priorité 1 / T1219.002	Agent Windows (Sysmon)	Lancement de processus RMM (TeamViewer, AnyDesk) non validés par la DSI
SOC-U C-03	MFA Fatigue	Priorité 1 / T1621	Intégration API (Azure AD / VPN)	> 5 échecs/refus MFA en < 10 min pour un même utilisateur, suivis d'un succès
SOC-U C-04	Altération fichiers Web (FIM)	Priorité 2 / T1059.007	Syscheck (FIM) sur serveurs Nginx	Modification ou création de fichiers .js / .php dans les répertoires web
SOC-U C-05	Trafic POST sortant anormal	Priorité 2 / T1048.003	Ingestion Syslog (Stormshield)	Volume élevé de requêtes HTTP POST depuis la DMZ web vers des IP externes inconnues
SOC-U C-06	Effacement des logs Windows	Priorité 3 / T1685.005	Agent Windows (EventChannel)	Event ID 1102 (audit log cleared) sur un serveur Windows
SOC-U C-07	Injection SQL sur BRIEF	Audit — VULN-WEB-SQL I-P01	Agent Linux (Logs Apache/PHP)	Requêtes POST avec signatures SQL (UNION, SELECT) sur l'URI de connexion port 8081
SOC-U C-08	Auth suspecte Grafana	Audit — VULN-MONITO R-DEFAULT-P01	Agent Linux (Logs Grafana)	Authentification réussie avec l'utilisateur admin par défaut sur le port 9090
SOC-U C-09	Scraping API IoT	Audit — VULN-WEB-API-P01	Agent Linux (Logs Nginx)	Volume HTTP 200 anormalement élevé vers les endpoints API BOXER depuis une IP unique
SOC-U C-10	Brute force panel admin	Audit — VULN-WEB-AUT H-P01	Agent Linux (Logs Apache/PHP)	> 5 tentatives échouées (HTTP 401/403) en < 60 s sur l'interface d'administration BRIEF
SOC-U C-11	Trafic hôtes obsolètes	Audit — Périmètre OT (XP/Win7)	Ingestion Syslog (Stormshield)	Flux entrant vers IP des systèmes obsolètes hors protocoles métiers stricts